

Phishing Email Analysis Lab

Offline triage of simulated account, invoice, and control messages

3	11	0
email samples	scored findings	network requests

Executive summary

This project analyzes three fictional email messages using both manual review and a Python triage tool. The analysis compares sender domains, SPF/DKIM/DMARC results, URLs, urgent language, and attachment filenames. The account alert scored High, the invoice lure scored High at the 70-point boundary, and the legitimate control scored Low.

The main lesson is that no single signal decides whether an email is safe. The invoice sample passed all three simulated authentication checks but still contained an unrelated Reply-To address, mismatched payment link, pressure language, and an HTML attachment.

Safety: Every organization and domain is fictional. Reserved namespaces prevent the URLs from leading to real services. The tool works entirely offline, never opens links, and never executes attachments.

Report date	Environment	Primary tool
August 29, 2026	Offline local lab	Python 3 standard library

1. Lab design

Objective

Practice a repeatable defensive workflow for examining suspicious email without interacting with live infrastructure. The lab produces evidence that can be reviewed by another analyst: original `.eml`` samples, structured JSON results, written case analysis, a defanged IOC list, tests, and this report.

Samples

Sample	Purpose	Expected comparison
Account alert	Simulates sender spoofing and a credential-themed lure	Multiple technical and social-engineering indicators
Invoice attachment	Simulates a business email with authentication passes	Content and context still justify escalation
Security notice	Legitimate control message	Aligned domains and no scored indicators

Workflow

- Preserve the original email and confirm analysis authorization.
- Compare From, Reply-To, Return-Path, and authenticated domains.
- Review SPF, DKIM, and DMARC outcomes recorded by the receiving system.
- Extract URLs without visiting them and compare their domains with the sender.
- Identify urgent language and attachments that require controlled handling.
- Document a verdict, IOCs, response actions, and limitations.

Safety controls

All domains end in `.example``, `.test``, or `.invalid``; the HTML attachment contains only a training notice; analysis makes no network calls; and attachments are recorded by filename only.

2. Analyzer and scoring

The analyzer uses Python's standard `email` package to parse local files. It extracts selected headers, readable body parts, URLs, and attachment filenames. Each finding adds a documented weight, and the total is capped at 100.

Rule	Indicator	Points
HDR-001	Reply-To domain differs from From	20
HDR-002	Return-Path domain differs from From	15
AUTH-SPF	SPF issue	20
AUTH-DKIM	DKIM issue	15
AUTH-DMARC	DMARC issue	25
URL-001	Linked domain differs from From	20
TXT-001	Urgent or pressuring language	10
ATT-001	Potentially risky attachment extension	20

Risk bands

Score	Triage level	Meaning
70-100	High	Quarantine or escalate promptly.
40-69	Medium	Validate through trusted channels and investigate.
0-39	Low	No strong scored indicators; continue normal judgment.

Example command

```
python src/analyze_email.py samples/01-account-alert.eml --json-out results/01-account-alert.json
```

The score is intentionally explainable. It is a lab triage aid, not a machine-learning model or a replacement for a secure email gateway.

3. Case analysis

Sample 01 - Account alert

HIGH - 100/100

The sample combined sender-domain mismatches with failed authentication, an unrelated link domain, and pressure language. These independent indicators reinforced one another.

Rule	Evidence	Points
HDR-001	From domain clouddesk.example differs from Reply-To domain clouddesk-support.test.	20
HDR-002	From domain clouddesk.example differs from Return-Path domain mailer.invalid.	15
AUTH-SPF	Authentication-Results reported spf=fail.	20
AUTH-DKIM	Authentication-Results reported dkim=fail.	15
AUTH-DMARC	Authentication-Results reported dmarc=fail.	25
URL-001	Message links to domain(s) not matching the visible sender: clouddesk-support.test.	20
TXT-001	Matched term(s): immediately, suspended, today, urgent.	10

Analyst verdict

Quarantine and investigate. Search mail telemetry for the sender, reply domain, return path, subject, and linked domain. If similar messages reached users, notify them through an approved internal channel.

Defanged IOC

```
hxxps://clouddesk-support[.]test/verify
```

Case analysis - continued

Sample 02 - Invoice attachment

HIGH - 70/100

The sample passed SPF, DKIM, and DMARC, but the message still used a different Reply-To domain, an unrelated payment link, pressure language, and an HTML attachment. Authentication supported the sender domain's use; it did not prove that the payment request was trustworthy.

Rule	Evidence	Points
HDR-001	From domain northwind.example differs from Reply-To domain northwind-payments.invalid.	20
URL-001	Message links to domain(s) not matching the visible sender: northwind-payments.invalid.	20
TXT-001	Matched term(s): action required, overdue, today.	10
ATT-001	Attachment filename(s): Invoice_8841.html.	20

Recommended response

Do not open the attachment on a normal workstation. Verify the invoice through a known vendor contact or established portal, inspect the attachment with approved tooling, and search for related messages.

Sample 03 - Legitimate control

LOW - 0/100

The sender domains aligned, all simulated authentication checks passed, the link returned to the visible sender's domain, and the message contained no risky attachment or pressure language. No scored indicators were detected.

A Low score is not a guarantee that a real message is safe. It means only that this tool did not detect its defined indicators.

4. Indicators and response

Defanged indicators

Sample	Type	Indicator	Confidence
01	Domain	clouddesk-support[.]test	High
01	Domain	mailer[.]invalid	High
01	URL	hxxps://clouddesk-support[.]test/verify	High
02	Domain	northwind-payments[.]invalid	Medium
02	URL	hxxps://northwind-payments[.]invalid/invoice/8841	Medium
02	File	Invoice_8841[.]html	Medium

Response sequence

Step	Action
1	Preserve the original message and record the message identifier.
2	Quarantine or isolate the message according to policy.
3	Search for related senders, subjects, domains, URLs, and message IDs.
4	Validate business requests through a known, independent channel.
5	Block confirmed indicators using approved controls.
6	Notify affected users and escalate interaction through incident response.
7	Document evidence, actions, final disposition, and limitations.

Analyst caution

Blocking an indicator without validation can interrupt legitimate communication. Conversely, authentication passes can occur in compromised-account or abused-service scenarios. Decisions should combine technical evidence with organizational context.

5. Lessons, limitations, and references

What this lab demonstrates

- How to read and compare common sender identity fields.
- How SPF, DKIM, and DMARC contribute evidence without deciding the case alone.
- How to extract and safely defang URLs and other indicators.
- How automation can make triage repeatable while leaving final judgment to an analyst.
- How to communicate a verdict, evidence, response, and limitations.

Limitations

- The messages and infrastructure are simulated.
- The analyzer trusts the supplied Authentication-Results header and does not query DNS.
- No reputation, sandbox, mail-gateway, or identity-provider telemetry is available.
- Attachments are classified by filename only and are never opened or executed.
- The scoring weights are educational and require analyst review.

References

1. [CISA - Recognize and Report Phishing](#)
2. [IETF RFC 7208 - Sender Policy Framework](#)
3. [IETF RFC 6376 - DKIM Signatures](#)
4. [IETF RFC 9989 - DMARC](#)
5. [IETF RFC 8601 - Authentication-Results Header](#)

Final assessment

The project met its objective: it produced a safe, reproducible phishing-triage workflow with explainable results, a legitimate control for comparison, structured evidence, tests, and actionable response recommendations.